8. f. The only check required is to compare the hash of the certificate. The AS performs all other checks when it issues the access token. While an API can optionally implement additional checks, these are not required for security.
9. False. A client can request certificate-bound access tokens even if it uses a different client authentication method. Even a public client can request certificate-bound access tokens.
10. a and d.
11. d.
12. a - HKDF-Expand. HKDF-Extract is used to convert non-uniform input key material into a uniformly random master key.
13. c
14. e

[1] OAuth2 Basic authentication requires additional URL-encoding if the client ID or secret contain non-ASCII characters. See https://tools.ietf.org/html/rfc6749#section-2.3.1 for details.

[2] There are additional sub-protocols that are used to change algorithms or keys after the initial handshake and to signal alerts, but you don't need to understand these.

[3] The database must be restarted because the Natter API tries to recreate the schema on startup and will throw an exception if it already exists.

[4] The Istio sidecar proxy is based on Envoy, which is developed by Lyft, in case you're wondering about the examples!

[5] Istio gateway is not just a Kubernetes ingress controller. An Istio service mesh may involve only part of a Kubernetes cluster, or may span multiple Kubernetes clusters, while a Kubernetes ingress controller always deals with external traffic coming into a single cluster.

[6] The code in listing 11.9 does parse the certificate as a side-effect of decoding the header with a CertificateFactory, but you could avoid this if you wanted to.

[7] If you're using the IBM JDK, use the name "PKCS11IMPLKS" instead.